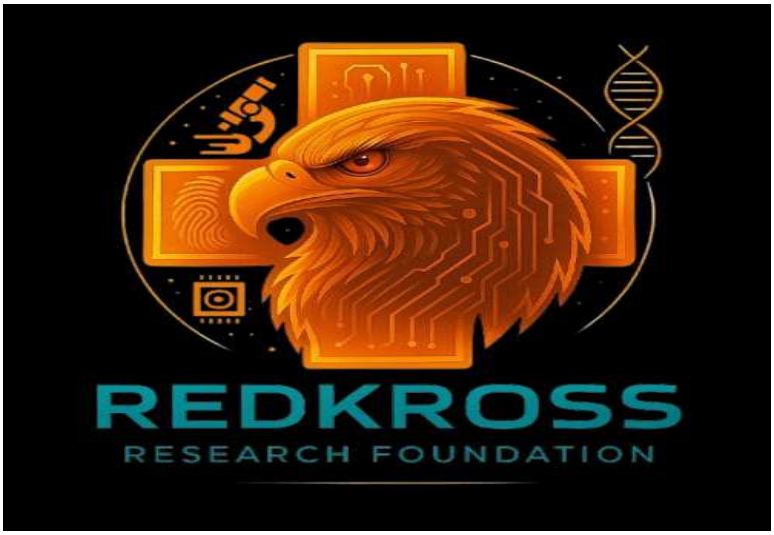


REDKROSS RESEARCH FOUNDATION

CYBERSECURITY INTERNSHIP PROJECT

WEBSITE CYBERSECURITY RISK ASSESSMENT

TECHNICAL REPORT

Prepared by	Dany Geo Johnson
Intern ID	2419
Assessment organisation	ABC Online Services
Submission deadline	25 October 2026

INDEX TABLE

No	Table of Contents	Pg. No
	Executive Summary	3
1	Project Objective	3
2	Background and Context	3
3	Scope	4
4	Research and Reference Frameworks	4
5	Methodology	5
6	Risk Scoring Method	5
7	Risk Register Findings	6
8	Prioritised Mitigation Recommendations	6
9	Existing Controls and Residual Risk	7
10	Tools and Work Products	8
11	Limitations	8
12	Conclusion	8
13	References	8
14	Supporting Evidence and Visuals	9
14.1	Risk register overview	9
14.2	Inherent risk score comparison	9
14.3	Asset inventory	10
14.4	Research basis and scope evidence	10
15	End-to-End Project Workflow	11
16	Assumptions and Interpretation Guide	11

Executive Summary

This report documents a qualitative cybersecurity risk assessment for ABC Online Services, a representative customer facing website scenario created for this internship task. The assessment identifies ten candidate risk scenarios affecting website functionality, customer data, user and administrator accounts, software dependencies, security monitoring, service availability and recovery.

The risk register uses a project defined five point likelihood scale and five point impact scale. The inherent score is calculated as likelihood multiplied by impact. Initial illustrative scores identify injection and broken access control as the highest-scoring candidate risks, followed by risks involving cryptographic protection, authentication, configuration, dependencies, logging, denial of service and recovery. The register proposes mitigations, role-based owners and estimated residual ratings.

The scenario is hypothetical and no production system, website configuration or incident evidence was provided. No penetration test, vulnerability scan or live technical testing was performed. Therefore, the risks and scores in this report are planning assessments, not confirmed vulnerabilities or measured probabilities. The proposed controls and residual-risk estimates must be validated before being treated as operational results.

1. Project Objective

The objective is to identify, analyse and prioritise cybersecurity risks associated with a representative website, and to recommend proportionate treatments. The work addresses the assignment requirements to document assets, threats, weaknesses, likelihood, impact, existing controls, treatment actions, owners and residual risk, with assumptions stated clearly.

2. Background and Context

ABC Online Services is an example organisation assumed to operate a website where customers can register, sign in and access profile information. The scenario includes a web application, authentication and session handling, an administrative portal, a database, third party software dependencies, security logs and backup/recovery processes. These details are scenario assumptions and are not statements about an actual business.

Web applications may face risks involving unauthorised access, unsafe input handling, configuration weaknesses, data protection, software dependencies, detection gaps and service disruption. The assessment uses public security guidance to identify candidate scenarios and structure risk management.

3. Scope

3.1 In scope

- Customer account and profile information.
- Website application and input handling functions.
- Authentication, sessions and account permissions.
- Administrative portal and privileged accounts.
- Database and data storage.
- Third party software dependencies.
- Security logs, alerts and incident escalation.
- Website availability, backups and recovery.

3.2 Out of scope

- Penetration testing or exploitation of a live website.
- Vulnerability scanning of a production environment.
- Verification of actual security configurations or control effectiveness.
- A full enterprise-wide audit, compliance certification or legal assessment.

4. Research and Reference Frameworks

4.1 NIST Cybersecurity Framework 2.0

NIST CSF 2.0 provides a flexible structure for understanding, assessing, prioritising and communicating cybersecurity risks. Its six Functions are Govern, Identify, Protect, Detect, Respond and Recover. In this project, these concepts inform the definition of scope and ownership, identification of assets and risk scenarios, selection of mitigations, consideration of monitoring, and recommendations for response and recovery.

Reference: https://www.nist.gov/cyberframework

4.2 OWASP Top 10:2025

OWASP Top 10:2025 is an awareness resource describing prominent web application security risk categories. It informs candidate scenarios related to broken access control, security misconfiguration, software supply chain failures, cryptographic failures, injection, insecure design, authentication failures, software or data integrity, logging and alerting, and mishandling of exceptional conditions. The list is used as guidance, not as proof that the example website contains any particular weakness.

Reference: https://owasp.org/www-project-top-ten/

Additional reference: https://top10.owasp.org/2025/0x00_2025-Introduction/

5. Methodology

1. Define the representative website scenario and state assumptions and limitations.
2. Identify assets and the security properties that matter to them, including confidentiality, integrity and availability.
3. Develop candidate threat scenarios and the weaknesses or control gaps that could make each scenario possible.
4. Record known information separately from assumed or unverified control information.
5. Assign qualitative likelihood and impact ratings using the project scoring guide, with a written rationale for each.
6. Calculate inherent risk scores and classify them using the documented score bands.
7. Recommend treatment actions and identify an appropriate role-based owner for each risk.
8. Estimate residual risk after proposed treatment, clearly labelling estimates as unverified.
9. Prioritise treatments and document limitations and references.

6. Risk Scoring Method

Likelihood and impact are each rated from 1 to 5. The score is calculated as

Risk Score = Likelihood × Impact

producing a range from 1 to 25. The project defined bands are Low (1–4), Medium (5–9), High (10–16) and Critical (17–25). These thresholds are chosen for this assessment and are not presented as thresholds mandated by NIST or OWASP.

Rating	Likelihood meaning	Impact meaning
1	Rare	Negligible
2	Unlikely	Minor
3	Possible	Moderate
4	Likely	Major
5	Almost certain	Severe

Likelihood ratings are qualitative judgements based on the plausibility of a scenario, assumed exposure and uncertainty about controls. Impact ratings consider potential effects on confidentiality, integrity, availability, privacy, operations and recovery. Scores should be revised if reliable system-specific evidence becomes available.

Inherent risk refers to risk before considering controls. Residual risk refers to risk expected to remain after treatment. In this assessment, residual scores are estimates based on proposed treatments, not measured outcomes.

7. Risk Register Findings

The accompanying Excel workbook contains ten candidate risks. The following table summarises their initial inherent scores. Scores are illustrative and should be interpreted in light of the stated assumptions.

ID	Risk	Likelihood × Impact	Inherent level
R01	Injection	4 × 5	20 - Critical
R02	Broken access control	4 × 5	20 - Critical
R03	Authentication failures	3 × 4	12 - High
R04	Security misconfiguration	3 × 4	12 - High
R05	Cryptographic failures	3 × 5	15 - High
R06	Software supply-chain failures	3 × 4	12 - High
R07	Logging and alerting failures	3 × 4	12 - High
R08	Availability and recovery	3 × 4	12 - High
R09	Denial of service	3 × 4	12 - High
R10	Security headers and transport configuration	3 × 3	9 - Medium

8. Prioritised Mitigation Recommendations

8.1 P1: Treat first

- Injection: use parameterised queries and safe APIs, conduct secure code review, validate input appropriately and arrange authorised testing.
- Broken access control: enforce server-side authorisation on protected operations, apply least privilege and review role/object-level permissions.
- Cryptographic failures: classify data, enforce appropriately configured TLS, protect sensitive stored data where required and manage keys securely.

8.2 P2: High priority

- Authentication: strengthen password handling, rate limiting, session management and multifactor authentication for privileged accounts.
- Security misconfiguration: apply hardened configuration baselines, remove default/debug settings and restrict administrative interfaces.
- Software supply chain: inventory dependencies, use trusted sources, monitor advisories and maintain a patch/update process.
- Logging and alerting: log relevant security events, protect logs, configure actionable alerts and define escalation responsibilities.
- Backup and recovery: define recovery objectives, protect and isolate backups, monitor backup jobs and test restoration.
- Denial of service: apply proportionate traffic filtering and rate limiting, monitor availability and define escalation and recovery procedures.

8.3 P3: Planned improvement

- Security headers and transport configuration: enforce HTTPS and appropriately configured TLS, and select browser security headers suitable for the application. Validate compatibility and effectiveness before relying on them.

Priorities are proposed for this example scenario. A real organisation would review them against business criticality, risk appetite, available evidence, implementation effort and dependencies.

9. Existing Controls and Residual Risk

The scenario does not provide evidence of current security controls. The register therefore records control information as unknown or unverified rather than claiming that controls are absent. Recommended treatments describe future actions. The residual likelihood and impact values are estimates used to illustrate how a reassessment might be documented after treatment; they are not proof that risk has already been reduced.

To validate residual risk in a real environment, an authorised owner would need to confirm that controls have been implemented, examine appropriate evidence and assess whether the controls work as intended. Risk acceptance or treatment decisions should be approved by the responsible organization

10. Tools and Work Products

- Microsoft Excel: risk register, scoring formulas, risk classification, priorities and asset inventory.
- Microsoft Word: project scope, research notes and this technical report.
- NIST CSF 2.0 and OWASP Top 10: public reference guidance for risk management and web application risk categories.
- GitHub: planned repository for the README, register, report and supporting files.

No penetration-testing tool, vulnerability scanner or live target was used for this hypothetical assessment. The work performed consists of desk research, scenario definition and qualitative risk analysis.

11. Limitations

- The organisation and website environment are representative assumptions, not a real assessed system.
- No system architecture, actual control evidence, incident history or business-impact analysis was provided.
- No live technical testing was performed; candidate risks are not confirmed vulnerabilities.
- Risk scores depend on the assumptions and should be revisited if reliable evidence becomes available.
- Residual-risk estimates are illustrative and require validation after treatment implementation.

12. Conclusion

This project establishes a structured starting point for managing cybersecurity risks in a representative website environment. Ten candidate risks have been documented with assets, threats, weaknesses, qualitative scores, proposed treatments, role-based owners and estimated residual ratings. The register highlights access-control and injection scenarios for early attention, while also addressing data protection, authentication, configuration, dependencies, monitoring, availability and recovery. The main limitation is the absence of system-specific evidence; therefore, the assessment should be treated as an assumption-based planning exercise rather than a technical audit.

13. References

1. National Institute of Standards and Technology (NIST). Cybersecurity Framework (CSF) 2.0. https://www.nist.gov/cyberframework
2. NIST. CSF 2.0: Resource & Overview Guide. https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1299.pdf
3. OWASP Foundation. OWASP Top 10:2025. https://owasp.org/www-project-top-ten/
4. OWASP Foundation. Introduction to OWASP Top 10:2025. https://top10.owasp.org/2025/0x00_2025-Introduction/

14. Supporting Evidence and Visuals

The figures and tables in this section are embedded directly in this report so a reader can understand the core project without opening the workbook. They are generated from the project workbook for readability. They are not screenshots of a live website, security tool output, or evidence of live testing. The editable workbook and original research files remain separate project artefacts.

14.1 Risk register overview

This summary shows the ten candidate risk scenarios, their inherent scores, risk levels and treatment priorities. The workbook contains the detailed rationales and treatment fields.

ID	Risk scenario	Likelihood	Impact	Score (L × I)	Level	Priority
R01	Injection	4	5	**20**	**Critical**	**P1 - Treat first**
R02	Broken access control	4	5	**20**	**Critical**	**P1 - Treat first**
R03	Authentication failures	3	4	**12**	**High**	P2 - High priority
R04	Security misconfiguration	3	4	**12**	**High**	P2 - High priority
R05	Cryptographic failures	3	5	**15**	**High**	**P1 - Treat first**
R06	Software supply chain failures	3	4	**12**	**High**	P2 - High priority
R07	Logging and alerting failures	3	4	**12**	**High**	P2 - High priority
R08	Availability and recovery	3	4	**12**	**High**	P2 - High priority
R09	Denial of service	3	4	**12**	**High**	P2 - High priority
R10	Security headers and transport configuration	3	3	**9**	**Medium**	P3 - Planned improvement

Figure 1. Consolidated risk register view generated from the workbook.

14.2 Inherent risk score comparison

Scores are qualitative prioritisation estimates, not measured probabilities or proof that a vulnerability exists.

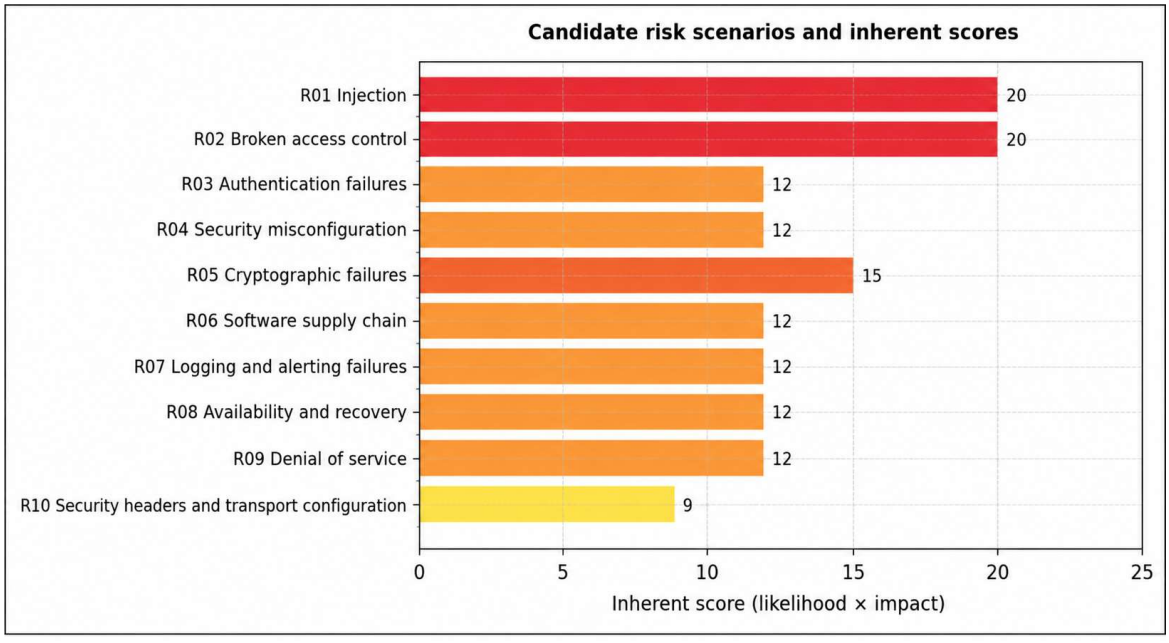


Figure 2. Inherent scores calculated using the project-defined likelihood × impact method.

14.3 Asset inventory

The inventory describes assumed website assets and their business purpose. The full workbook also records potential consequences if each asset is compromised.

Asset Inventory for the Representative Website

Asset ID	Asset	Business purpose / data	Security properties	Potential impact if compromised
A-01	Customer account data	Stores customer names, email addresses, password hashes and profile information used for account access and services.	Confidentiality, integrity, availability, privacy	Unauthorised access to customer accounts, data breaches, reputational damage and regulatory consequences.
A-02	Website application	Processes user registration, login, profile management and other customer-facing functions.	Integrity, confidentiality, availability	Manipulation of application functions, unauthorised access, data theft or service disruption.
A-03	Authentication and session management	Controls user sign-in, session tokens and account permissions.	Confidentiality, integrity, availability	Account takeover, unauthorised access to customer or administrative functions.
A-04	Administrative portal	Supports staff administration, content management and system configuration.	Integrity, confidentiality, availability	Unauthorised administrative access, malicious changes, or complete system compromise.
A-05	Database and storage	Stores account records, application data, logs and configuration information.	Confidentiality, integrity, availability	Exposure or loss of sensitive data, service disruption and data corruption.
A-06	Third-party software and dependencies	Libraries, frameworks and external services used by the website.	Integrity, availability, confidentiality	Introduction of vulnerabilities, supply-chain attacks or service disruption from third-party issues.
A-07	Security logs and alerts	Records system, application and security events to support monitoring and incident response.	Integrity, availability, confidentiality	Reduced ability to detect, investigate and respond to security incidents.
A-08	Backups and recovery	Stores backup copies of website data and configurations to support recovery after an incident.	Availability, integrity, confidentiality	Inability to recover data or services after a failure, leading to prolonged outage and data loss.

Figure 3. Asset inventory for the representative website (hypothetical scenario).

Figure 3. Asset inventory summary generated from the workbook

14.4 Research basis and scope evidence

The assessment was structured around public guidance from the NIST Cybersecurity Framework (CSF) 2.0 and the OWASP Top 10:2025. The project scope document defines ABC Online Services as a hypothetical organisation and states that no live testing was performed. These source and scope records provide the rationale for the assessment; they are not screenshots of technical testing.

Reference / artefact	Use in this project	Where maintained
NIST Cybersecurity Framework 2.0	Provides a high-level structure for cybersecurity risk management.	Research notes and References section
OWASP Top 10:2025	Informs candidate web application risk scenarios.	Research notes and References section
Project Scope and Assumptions	Defines the hypothetical organisation, scope and limitations.	Project-Planning
Cybersecurity Research Notes	Summarises the public guidance and candidate risk scenarios.	Research
Risk Register workbook	Contains detailed risk-by-risk scoring and treatment fields.	Risk-Register

15. End-to-End Project Workflow

1. Define the hypothetical organisation, website functions, scope and explicit assumptions.
2. Review public cybersecurity guidance from NIST CSF 2.0 and OWASP Top 10:2025.
3. List relevant assets and develop candidate threat and weakness scenarios.
4. Score likelihood and impact using the project-defined five-point scales and record the rationale.
5. Prioritise treatments, assign role-based owners and estimate residual risk after proposed treatment.
6. Document findings and limitations in this report and maintain detailed risk-by-risk fields in the Excel workbook.
7. Package the scope document, research notes, workbook, report and supporting evidence in the project repository.
8. Record the explanatory walkthrough and submit the repository and video links in the official tracker.

16. Assumptions and Interpretation Guide

- ABC Online Services is a fictional example used only to structure the assessment.
- Assets, threats and weaknesses are candidate scenarios, not confirmed conditions in a real system.
- Existing controls are treated as unknown or unverified unless supported by evidence.
- Likelihood and impact scores are qualitative judgements based on the stated scenario.
- Residual-risk scores are illustrative estimates of possible remaining risk after treatment; they are not measured results.
- Risk owners are suggested roles, not named employees or confirmed organisational assignments.
- This report explains context and interpretation; the workbook preserves detailed risk-by-risk fields.